GRC103 Social Engineering & Phishing Campaign

Social Engineering & Phishing Campaign Simulation for GRC Professionals

Student Information	
Full Name	Khodani Netshifhefhe
Registration Number	C11/26/CGRCE/17580
Email Address	c11.cgrce2617580@icdfa.edu.ng
Submission Date	08 November 2026

Report for Q3 Controlled Phishing Simulation

To: CISO, Head of HR, and Executive Management

From: GRC Audit Team

Date: 08 November 2026

Subject: Results of Q3 Controlled Phishing Simulation and Human Risk Assessment

1. Executive Summary

A controlled, internal phishing simulation was conducted using the GoPhish framework to assess organisational resilience to social engineering attacks. A test group of three users was targeted with a benign, simulated phishing email impersonating an internal IT security notice. The results indicate a meaningful level of human risk which showed that two of the three targeted users (67%) opened the email, and both of those users (67% of the total group) went on to click the embedded malicious link. No credentials were submitted on the simulated landing page in this round.

2. Key Findings & Metrics

- Email Open Rate is 67% indicating engagement with a themed, urgency-based email.
- Link Click-Through Rate is 67% indicating a failure to identify or verify a suspicious link before clicking.
- Credential Submission Rate is 0% showing that no credentials were captured in this test round.

Note: this simulation used a small test group (n = 3). The percentages above should be read as directional indicators rather than statistically robust estimates.

3. Risk Assessment Table

Metric	Result	Calculated Rate	Risk Interpretation	Control Failure
Emails Opened	2/3	67%	The majority of targeted users engaged with a suspicious, urgency-themed email rather than treating it with caution.	Security awareness training on recognising suspicious senders and subject lines appears insufficient.
Links Clicked	2/3	67%	Of the users who opened the email, 100% went on to click the embedded link without first verifying the sender or URL.	Lack of habitual link-verification behaviour, the urgency-based pretext was not questioned.
Credentials Submitted	0/3	0%	No credentials were captured on the simulated landing page in this test round.	No control failure indicated by this metric alone and however, the very small sample size (n = 3) limits confidence in this result.

4. Risk Analysis

This data indicates that, at minimum, user awareness around identifying and verifying suspicious emails requires reinforcement. A click-through rate of 67% on a simple, urgency-themed pretext suggests that if this had been a real attack, a majority of the targeted group could have been redirected to a credential-harvesting site. Although no credentials were submitted in this instance, the small sample size means this should not be interpreted as evidence that the organisation's credential-handling behaviour is adequate.

A successful real-world phishing attack exploiting this same behaviour pattern could lead to:

- Initial network access for attackers via compromised credentials.
- Data breaches and associated financial loss.
- Reputational damage and regulatory exposure (e.g. under GDPR, POPIA, or equivalent data-protection regimes).

5. Recommended Actions

- Immediate Technical Control - Accelerate the rollout of Multi-Factor Authentication (MFA) across all critical systems.
- Expand the Test Sample - Re-run this simulation against a larger, representative user group to validate whether the 67% open/click rates observed here hold at scale.
- Revamp Training Program- Move from annual compliance videos to continuous, engaging, and scenario-based phishing-awareness training.
- Process Integration - Incorporate phishing simulations into new-hire onboarding and run them on a recurring basis for example, on a quarterly basis for all staff.
- Policy Update - Review and update the Acceptable Use Policy (AUP) to explicitly define requirements for identifying and reporting phishing attempts.

6. Limitations

This simulation was conducted against a test group of three users rather than a full department or organisation, as a controlled lab exercise. Despite the small sample size, it is concerning given how quickly engagement occurred.

7. Conclusion

This exercise demonstrates that measurable human risk exists within even a small test population, and that technical controls (MFA) combined with improved, continuous awareness training are necessary to reduce the organisation's exposure to credential-based phishing attacks. The GRC team recommends management approve the actions outlined in Section 5 and allocate budget for an expanded simulation and training programme.